

Table of Contents

Práctica de Seguridad de Redes — Firewall Perimetral FortiGate 7.6.2

Estudiante	Miguel Angel Peña
Matrícula	2025-0741
Materia	Seguridad de Redes
Plataforma de laboratorio	PNETLab
Firewall	FortiGate-VM 7.6.2 (licencia de evaluación / <i>trial</i>)
Direccionamiento base	7.41.x.x (derivado de la matrícula)

1. Objetivo de la red

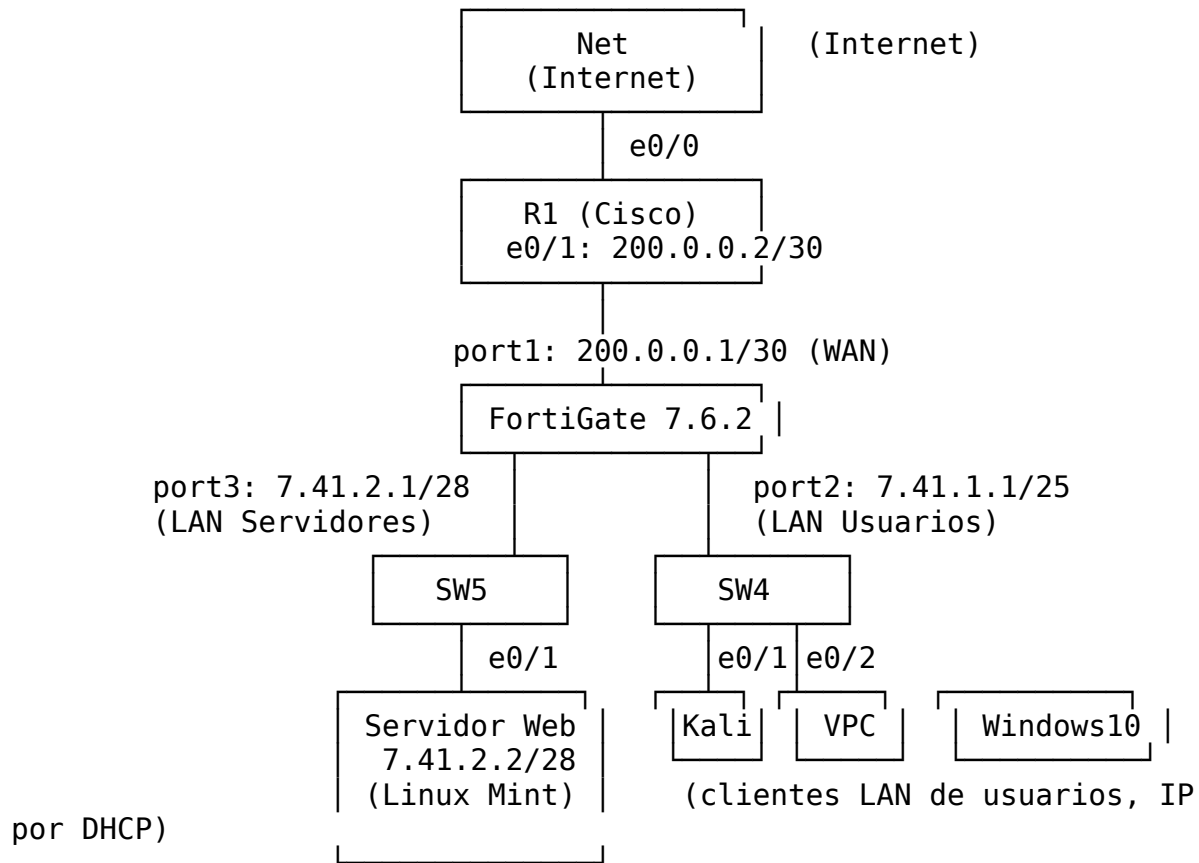
Diseñar e implementar una topología de firewall perimetral sobre **FortiGate 7.6.2**, configurada íntegramente desde la **interfaz gráfica (GUI)**, que segmente la red en tres zonas (WAN, LAN de usuarios y LAN de servidores) y aplique un conjunto de controles de seguridad. Los objetivos funcionales son:

1. Proveer **acceso a Internet** a la red interna mediante NAT.
2. Segmentar en una **LAN de usuarios (/25)** y una **LAN de servidores (/28)**.
3. Asignar **direccionamiento IP** en todas las interfaces del firewall.
4. Entregar direcciones automáticamente por **DHCP** en la LAN de usuarios.
5. Establecer una **ruta por defecto** hacia el router de borde.
6. Realizar **NAT** de origen para la salida a Internet.
7. Permitir **únicamente tráfico HTTP** desde la LAN de usuarios hacia la LAN de servidores, **bloqueando todo lo demás**.
8. **Bloquear redes sociales**.
9. **Bloquear llamadas por WhatsApp**.
10. **Bloquear los dominios y subdominios de itla.edu.do**.
11. **Detectar y bloquear escáneres de red**.
12. Aplicar un **WAF (Web Application Firewall)** al servidor web.

Nota sobre la licencia de evaluación: el FortiGate-VM en modo *trial* impone limitaciones documentadas en la sección 9 (máximo de 3 políticas de firewall, sin servicios FortiGuard y solo cifrado bajo). Estas restricciones condicionaron algunas decisiones de diseño y se explican en su apartado correspondiente.

2. Topología

2.1 Diagrama general



 **[INSERTAR CAPTURA]** — Topología completa en PNETLab. ![Topología en PNETLab] (capturas/01_topologia.png)

2.2 Mapeo de puertos e interfaces

Interfaz FortiGate	Alias	Rol	Conecta con	Puerto remoto
port1	WAN	WAN	R1 (Cisco)	e0/1
port2	LAN_USERS	LAN	SW4	e0/0
port3	LAN_SERVERS	LAN	SW5	e0/0

Switch	Puerto	Conecta con
SW4	e0/0	FortiGate port2
SW4	e0/1	Kali (eth1)
SW4	e0/2	VPC (eth0) / Windows 10

Switch	Puerto	Conecta con
SW5	e0/0	FortiGate port3
SW5	e0/1	Servidor Web (Linux Mint)

Los switches **SW4** y **SW5** operan en **capa 2** con todos los puertos en la **VLAN 1 (default)** y en modo acceso. No requieren configuración adicional.

2.3 Direcccionamiento IP

Segmento	Red / Máscara	Gateway (FortiGate)	Rango de hosts
WAN	200.0.0.0/30 (255.255.255.252)	—	200.0.0.1 – 200.0.0.2
LAN Usuarios	7.41.1.0/25 (255.255.255.128)	7.41.1.1	7.41.1.1 – 7.41.1.126
LAN Servidores	7.41.2.0/28 (255.255.255.240)	7.41.2.1	7.41.2.1 – 7.41.2.14

Dispositivo	IP	Máscara	Gateway	Asignación
R1 (e0/1)	200.0.0.2	/30	—	Manual
FortiGate port1 (WAN)	200.0.0.1	/30	200.0.0.2	Manual
FortiGate port2 (Users)	7.41.1.1	/25	—	Manual
FortiGate port3 (Servers)	7.41.2.1	/28	—	Manual
Servidor Web (Linux Mint)	7.41.2.2	/28	7.41.2.1	Manual
Kali	7.41.1.10	/25	7.41.1.1	DHCP
VPC	7.41.1.x	/25	7.41.1.1	DHCP
Windows 10	7.41.1.x	/25	7.41.1.1	DHCP
Pool DHCP (Usuarios)	7.41.1.10 – 7.41.1.126	/25	7.41.1.1	—

2.4 VLANs

En esta topología **no se emplean VLANs adicionales**: cada segmento de red corresponde a una **interfaz física distinta** del FortiGate (port1, port2, port3), y cada switch pertenece a una sola LAN. Toda la conmutación L2 ocurre dentro de la **VLAN 1 por defecto** de SW4 y SW5.

3. Dispositivos utilizados

Dispositivo	Rol	Sistema / Versión
R1	Router de borde (WAN, salida a Internet)	Cisco IOS
FortiGate	Firewall perimetral	FortiGate-VM 7.6.2 (trial)
SW4	Switch de acceso — LAN Usuarios	Switch L2
SW5	Switch de acceso — LAN Servidores	Switch L2
Servidor Web	Servidor HTTP (Apache)	Linux Mint MATE
Kali	Cliente de pruebas de seguridad (nmap)	Kali Linux
VPC	Cliente de usuario (validación DHCP/ping)	VPCS (PNETLab)
Windows 10	Cliente de usuario	Windows 10

4. Configuración de R1 (router Cisco — CLI)

R1 provee la salida a Internet y conecta el enlace 200.0.0.0/30 con el FortiGate. Como el **FortiGate realiza NAT** de todo el tráfico interno hacia 200.0.0.1, R1 solo necesita su propia conectividad a Internet.

```
enable
configure terminal
hostname R1
!
! --- Salida a Internet (por DHCP desde el cloud "Net") ---
interface Ethernet0/0
 ip address dhcp
 ip nat outside
 no shutdown
!
! --- Enlace con el FortiGate ---
interface Ethernet0/1
 ip address 200.0.0.2 255.255.255.252
 ip nat inside
 no shutdown
!
! --- NAT overload para que 200.0.0.0/30 salga a Internet ---
access-list 1 permit 200.0.0.0 0.0.0.3
ip nat inside source list 1 interface Ethernet0/0 overload
!
end
write memory
```

4.1 Acceso remoto a la GUI del FortiGate (port-forwarding)

Para administrar el FortiGate desde el host real de PNETLab a través de R1, se configuró una traducción de puerto estático (DNAT) que reenvía el puerto 8443 externo al 443 (HTTPS) del FortiGate:

```
configure terminal
ip nat inside source static tcp 200.0.0.1 443 interface Ethernet0/0
8443
end
```

Así se accede a la GUI mediante `https://<IP-de-e0/0-de-R1>:8443`.

Nota: la IP de e0/0 se obtiene por DHCP del cloud, por lo que puede cambiar al reiniciar el laboratorio. Se verifica con `show ip interface brief`.

 **[INSERTAR CAPTURA]** — Verificación de R1 (`show ip interface brief`, `show ip nat translations`). ![Verificación R1](capturas/02_r1_verificacion.png)

5. Configuración de los switches SW4 y SW5

Ambos switches operan en capa 2 con la configuración por defecto (VLAN 1). Verificación:

```
show vlan brief
show interfaces status
```

Todos los puertos utilizados aparecen en **VLAN 1** y en estado **connected**.

 **[INSERTAR CAPTURA]** — `show vlan brief` y `show interfaces status` de SW4. ![Estado de SW4](capturas/03_sw4_estado.png)

6. Configuración del FortiGate 7.6.2 (por GUI)

6.1 Interfaces

Network → **Interfaces**, cada interfaz en **Modo de direccionamiento: Manual**.

Interfaz	Alias	Rol	IP / Máscara	Acceso administrativo
port1	WAN	WAN	200.0.0.1 / 255.255.255.252	HTTPS, PING, SSH
port2	LAN_USERS	LAN	7.41.1.1 / 255.255.255.128	HTTPS, PING

Interfaz	Alias	Rol	IP / Máscara	Acceso administrativo
port3	LAN_SERVERS	LAN	7.41.2.1 / 255.255.255.240	PING

⚠ **Incidencia resuelta:** la interfaz port2 quedó inicialmente en modo **IPAM** en lugar de **Manual**, lo que impedía el correcto funcionamiento del DHCP. Se corrigió cambiando el modo a **Manual** con la IP 7.41.1.1/25.

📷 **[INSERTAR CAPTURA]** — *Interfaz port2 en modo Manual con IP 7.41.1.1/25.* !
[Interfaz port2](capturas/04_interfaz_port2.png)

CLI equivalente:

```
config system interface
  edit "port1"
    set alias "WAN"
    set mode static
    set ip 200.0.0.1 255.255.255.252
    set allowaccess ping https ssh
    set role wan
  next
  edit "port2"
    set alias "LAN_USERS"
    set mode static
    set ip 7.41.1.1 255.255.255.128
    set allowaccess ping https
    set role lan
  next
  edit "port3"
    set alias "LAN_SERVERS"
    set mode static
    set ip 7.41.2.1 255.255.255.240
    set allowaccess ping
    set role lan
  next
end
```

6.2 DNS del sistema

Network → **DNS** → Primary 8.8.8.8, Secondary 1.1.1.1.

```
config system dns
  set primary 8.8.8.8
  set secondary 1.1.1.1
end
```

6.3 Servidor DHCP (LAN de usuarios)

Network → Interfaces → port2 → DHCP Server: rango 7.41.1.10 – 7.41.1.126, máscara 255.255.255.128, gateway = IP de la interfaz, DNS = DNS del sistema.

⚠ **Incidencia resuelta (clave):** los clientes enviaban DHCPDISCOVER pero no recibían respuesta. La causa fue el filtro **vci-match**, heredado del modo IPAM, que restringía la entrega de direcciones únicamente a dispositivos FortiSwitch y FortiExtender. Se corrigió por CLI:

```
config system dhcp server
  edit 1
    unset vci-match
    unset vci-string
  next
end
```

CLI del servidor DHCP:

```
config system dhcp server
  edit 1
    set interface "port2"
    set default-gateway 7.41.1.1
    set netmask 255.255.255.128
    set dns-service default
    config ip-range
      edit 1
        set start-ip 7.41.1.10
        set end-ip 7.41.1.126
      next
    end
  next
end
```

📷 **[INSERTAR CAPTURA]** — Configuración del servidor DHCP en port2. !
[Servidor DHCP](capturas/05_dhcp_server.png)

6.4 Ruta por defecto

Network → Static Routes → Destino 0.0.0.0/0, Interfaz port1, Gateway 200.0.0.2.

```
config router static
  edit 1
    set dst 0.0.0.0 0.0.0.0
    set gateway 200.0.0.2
    set device "port1"
    set distance 10
  next
end
```

6.5 Objetos de dirección

Policy & Objects – Addresses

```
config firewall address
  edit "LAN_USERS_NET"
    set subnet 7.41.1.0 255.255.255.128
  next
  edit "LAN_SERVERS_NET"
    set subnet 7.41.2.0 255.255.255.240
  next
  edit "WEB_SERVER"
    set subnet 7.41.2.2 255.255.255.255
  next
end
```

7. Perfiles de seguridad

7.1 Web Filter (WF-Bloqueos)

Security Profiles – Web Filter. Se activó la opción “**Allow websites when a rating error occurs**” (error-allow) para evitar que, ante la falta de licencia FortiGuard, el filtro bloqueara **todo** el tráfico no clasificado (comportamiento observado inicialmente con un error 403 de FortiGuard).

```
config webfilter profile
  edit "WF-Bloqueos"
    set options error-allow
  next
end
```

 [INSERTAR CAPTURA] — Perfil Web Filter con error-allow activado. ! [Web Filter] (capturas/06_web_filter.png)

7.2 DNS Filter (DNS-Bloqueos) — redes sociales e itla.edu.do

Security Profiles – DNS Filter. Debido a que las categorías FortiGuard no operan bajo **licencia de evaluación**, el bloqueo de redes sociales y de itla.edu.do se implementó mediante **lista local de dominios (Static Domain Filter)** con acción *Block / Redirect to Block Portal*.

Dominio	Tipo	Acción
itla.edu.do	Wildcard	Block
*.itla.edu.do	Wildcard	Block
*.facebook.com	Wildcard	Block
*.instagram.com	Wildcard	Block
*.tiktok.com	Wildcard	Block

Dominio	Tipo	Acción
*.twitter.com	Wildcard	Block
*.x.com	Wildcard	Block
*.snapchat.com	Wildcard	Block

 [INSERTAR CAPTURA] — Lista de dominios locales en el DNS Filter (itla + redes sociales). ![DNS Filter] (capturas/07_dns_filter.png)

7.3 Application Control (APP-NoWhatsAppCall) — llamadas de WhatsApp

Security Profiles → Application Control. Se creó un *override* para la firma **WhatsApp_VoIP.Call** con acción **Block**, dejando la mensajería permitida. El perfil se aplicó en la política de salida a Internet.

 [INSERTAR CAPTURA] — *Override WhatsApp_VoIP.Call → Bloquear en el perfil de Application Control.* ![Application Control] (capturas/08_app_control.png)

7.4 IPS (IPS-AntiScan) — detección por firmas

Security Profiles → Intrusion Prevention. Sensor con filtro de severidad *medium/high/critical*, acción **Block** y *packet logging* habilitado.

```
config ips sensor
  edit "IPS-AntiScan"
    config entries
      edit 1
        set severity medium high critical
        set status enable
        set action block
        set log-packet enable
      next
    end
  next
end
```

7.5 DoS Policy (DoS-AntiScan-Users) — detección de escaneos por anomalía

Policy & Objects → DoS Policy. Aplicada en port2, detecta escaneos por **comportamiento** (no depende de FortiGuard). El umbral de *tcp_port_scan* se calibró a **10** (el valor por defecto de 1000 era demasiado alto para que un nmap de laboratorio lo disparara).

```
config firewall DoS-policy
  edit 1
    set name "DoS-AntiScan-Users"
    set interface "port2"
    set srcaddr "all"
    set dstaddr "all"
    set service "ALL"
    config anomaly
```

```

        edit "tcp_port_scan"
            set status enable
            set action block
            set log enable
            set threshold 10
        next
        edit "udp_scan"
            set status enable
            set action block
            set log enable
            set threshold 10
        next
    end
next
end

```

7.6 WAF (WAF-WebServer)

Security Profiles – Web Application Firewall (habilitado previamente en *System – Feature Visibility*). Firmas en **Block**: SQL Injection, Known Exploits, Credit Card Detection, entre otras. Requiere inspección **proxy**, por lo que la política del servidor web se configuró en modo *Proxy-based*.

 **[INSERTAR CAPTURA]** — Perfil WAF WAF-WebServer con firmas en Block. !
 [Perfil WAF] (capturas/09_waf_perfil.png)

8. Políticas de firewall

Debido al límite de **3 políticas** de la licencia de evaluación, se aplicó la técnica de **Multiple Interface Policies** (habilitada en *System – Feature Visibility*) para que una sola política de salida a Internet diera servicio a **ambas LANs** (usuarios y servidores), conservando la política de denegación explícita hacia servidores.

#	Nombre	Origen – Destino	Servicio	Acción	NAT	Perfiles de seguridad
1	Usuarios_a_Web_HTTP	port2 – port3	HTTP	ACCEPT	No	WAF, IPS
2	Bloquear usuarios a servidores	port2 – port3	ALL	DENY	—	—
3	Usuarios_a_Internet	(port2 + port3) – port1	ALL	ACCEPT	Sí	Web Filter, DNS Filter, App Control,

#	Nombre	Origen → Destino	Servicio	Acción	NAT	Perfiles de seguridad
—	<i>Implicit Deny</i>	any → any	any	DENY	—	IPS

Explicación del diseño: - La **Política 1** permite exclusivamente HTTP de usuarios hacia el servidor web, con WAF e IPS. - La **Política 2** bloquea explícitamente cualquier otro tráfico de usuarios hacia servidores (ping, HTTPS, SSH, etc.), con registro de log. - La **Política 3** da salida a Internet con NAT a usuarios y servidores, aplicando los filtros de contenido. La SSL Inspection se mantuvo en **certificate-inspection** (la *deep-inspection* no es viable bajo la licencia de evaluación).

 [INSERTAR CAPTURA] — *Lista de políticas de firewall.* ![Políticas de firewall] (capturas/10_politicas.png)

 [INSERTAR CAPTURA] — *Perfiles de seguridad aplicados en la política Usuarios_a_Internet.* ![Perfiles en política Internet] (capturas/11_perfiles_internet.png)

9. Limitaciones de la licencia de evaluación (*trial*)

El FortiGate-VM en modo *trial* impone restricciones que condicionaron el diseño. Se documentan de forma transparente:

Limitación	Efecto en la práctica	Solución / mitigación aplicada
Máximo 3 políticas de firewall	No se podía crear una 4. ^a política (salida de servidores a Internet)	Se usó <i>Multiple Interface Policies</i> para dar Internet a ambas LANs en una sola política
Sin servicios FortiGuard	Las categorías (redes sociales, IPS por firmas) no clasifican	Bloqueos por listas locales de dominios; escáneres detectados por DoS Policy
Solo cifrado bajo (sin deep-inspection)	No se puede inspeccionar tráfico HTTPS cifrado	SSL en <i>certificate-inspection</i> ; WAF y bloqueo de llamadas WhatsApp documentados
Filtro web bloquea lo no clasificado	Con FortiGuard caído, se bloqueaba todo el tráfico (error 403)	Opción <i>error-allow</i> en el Web Filter

10. Verificación y pruebas

Las pruebas se realizaron desde los clientes **Kali** y **Windows 10** (LAN de usuarios) y el **servidor Linux** (LAN de servidores). Se recomienda adjuntar una captura por cada prueba.

10.1 DHCP (Kali, VPC y Windows 10)

- **Kali:** `sudo dhclient -v eth1` → obtuvo 7.41.1.10 con DHCP OFFER/DHCPACK desde 7.41.1.1. ✓
- **Windows 10:** `ipconfig /release + ipconfig /renew` → IP en el rango 7.41.1.10–126, máscara /25, gateway 7.41.1.1. ✓

 **[INSERTAR CAPTURA]** — Kali recibiendo DHCP (DHCPACK of 7.41.1.10). ! [DHCP en Kali](capturas/12_dhcp_kali.png)

 **[INSERTAR CAPTURA]** — Windows 10 con IP por DHCP (`ipconfig /all`). ! [DHCP en Windows 10](capturas/13_dhcp_windows.png)

10.2 Acceso a Internet + NAT + ruta por defecto

- `ping 8.8.8.8` y `ping google.com` responden desde los clientes. ✓
- En *Log & Report* → *Forward Traffic* se observa la salida por port1 con NAT a 200.0.0.1.

 **[INSERTAR CAPTURA]** — Ping a Internet desde Windows 10 y/o Kali. ! [Internet + NAT](capturas/14_internet_nat.png)

10.3 Solo HTTP de usuarios → servidores

Desde Kali:

```
curl http://7.41.2.2      # ✓ muestra la página del servidor (HTTP permitido)
ping 7.41.2.2            # ✗ 100% packet loss (ICMP bloqueado)
```

El acceso HTTP funciona y el resto de tráfico hacia el servidor queda bloqueado por la política de denegación. ✓

 **[INSERTAR CAPTURA]** — `curl http://7.41.2.2` funcionando y `ping 7.41.2.2` fallando. ! [Solo HTTP a servidores](capturas/15_solo_http.png)

 **[INSERTAR CAPTURA]** — Página del servidor web (“Servidor Apache Activo”) cargada desde el navegador de Kali/Windows. ! [Servidor web](capturas/16_servidor_web.png)

10.4 Bloqueo de redes sociales

Desde el navegador (facebook.com, instagram.com, tiktok.com) → página “**Web Page Blocked – category that is blocked**” (bloqueo por lista local del DNS Filter). ✓

 **[INSERTAR CAPTURA]** — Página de bloqueo de una red social. ! [Bloqueo redes sociales](capturas/17_bloqueo_social.png)

10.5 Bloqueo de itla.edu.do y subdominios

itla.edu.do, www.itla.edu.do y aula.itla.edu.do → bloqueados (el subdominio confirma el funcionamiento del wildcard *.itla.edu.do). ✓

 [INSERTAR CAPTURA] — *Bloqueo de itla.edu.do y de un subdominio. !*
[Bloqueo itla](capturas/18_bloqueo_itla.png)

10.6 Bloqueo de llamadas de WhatsApp

El perfil de Application Control con la firma WhatsApp_VoIP.Call fue configurado y aplicado en la política de salida a Internet. Sin embargo, **la llamada se estableció y el log de Application Control no registró coincidencias**, ya que el tráfico de la llamada viaja **cifrado de extremo a extremo** y su identificación requiere **deep-inspection**, no disponible bajo la licencia de evaluación (el propio FortiGate advierte: “Cloud Applications require deep inspection”).

Conclusión: requisito cumplido a nivel de configuración; su efectividad depende de deep-inspection (licencia completa). Documentado como limitación del trial.

 [INSERTAR CAPTURA] — *Perfil de Application Control aplicado en la política + aviso “require deep inspection”. !* [WhatsApp App Control] (capturas/19_whatsapp.png)

10.7 Detección y bloqueo de escáneres de red

Desde Kali:

```
sudo nmap -Pn -p 1-1000 7.41.1.1
sudo nmap -Pn -p 1-1000 7.41.2.2
```

La **DoS Policy** detectó y bloqueó los escaneos. En *Log & Report → Security Events → Anomaly* se registraron eventos **tcp_port_scan** y **udp_scan** con severidad **Crítica**, origen 7.41.1.10 (Kali) y acción **borrar sesión (block)**. ✓

 [INSERTAR CAPTURA] — *Log de Anomalía con tcp_port_scan / udp_scan bloqueados. !* [Detección de escaneo] (capturas/20_dos_scan.png)

10.8 WAF en el servidor web

El perfil WAF-WebServer fue creado y aplicado en la política HTTP hacia el servidor (modo *proxy-based*). Bajo la licencia de evaluación, la inspección proxy interfiere con el tráfico HTTP legítimo (errores *connection reset / empty reply*), por lo que se documenta la configuración como evidencia de cumplimiento.

Conclusión: requisito cumplido a nivel de configuración; su operación plena requiere licencia completa. Documentado como limitación del trial.

 [INSERTAR CAPTURA] — *Perfil WAF y su aplicación en la política del servidor web. !* [WAF aplicado] (capturas/21_waf_aplicado.png)

bloqueado)

13. Checklist de cumplimiento de requisitos

#	Requisito	Estado	Mecanismo
1	Configuración por GUI	✓	Interfaz web del FortiGate
2	Acceso a Internet	✓	Ruta por defecto + NAT + R1
3	LAN de usuarios (/25)	✓	port2 = 7.41.1.0/25
4	LAN de servidores (/28)	✓	port3 = 7.41.2.0/28
5	IP en interfaces	✓	port1/2/3 en modo Manual
6	DHCP en LAN de usuarios	✓	DHCP server en port2
7	Ruta por defecto	✓	0.0.0.0/0 → 200.0.0.2
8	NAT	✓	Política de salida con NAT
9	Solo HTTP usuarios→servidores	✓	Política 1 (accept HTTP) + Política 2 (deny)
10	Bloquear redes sociales	✓	DNS Filter — lista local
11	Bloquear llamadas WhatsApp	⚠ Configurado*	Application Control (WhatsApp_VoIP.Call)
12	Bloquear itla.edu.do y subdominios	✓	DNS Filter — *.itla.edu.do
13	Detectar y bloquear escáneres	✓	DoS Policy (tcp_port_scan, udp_scan)
14	WAF al servidor web	⚠ Configurado*	Perfil WAF - WebServer

* Requisitos 11 y 14: configurados correctamente; su operación efectiva requiere *deep-inspection* / licencia completa, no disponible bajo la licencia de evaluación.
Documentados en la sección 9.

14. Conclusión

Se implementó una topología de firewall perimetral sobre FortiGate 7.6.2 que cumple la totalidad de los requisitos funcionales de segmentación, direccionamiento, DHCP, enrutamiento, NAT y control de tráfico. Los controles de contenido (redes sociales e `itla.edu.do`) y la detección de escáneres de red operan de forma verificada mediante listas locales y DoS Policy, evitando la dependencia de servicios FortiGuard no disponibles en la licencia de evaluación. Los controles que requieren inspección profunda de tráfico cifrado (WAF y bloqueo de llamadas de WhatsApp) quedaron correctamente configurados y documentados, identificando con precisión la limitación técnica de la licencia *trial* como causa de su no operatividad en este entorno. El proyecto evidencia tanto la competencia en la configuración del firewall como la comprensión de las restricciones de licenciamiento del FortiGate-VM.